

Q1: การที่แอปพลิเคชันเก็บรหัสผ่านเป็น Plaintext ในฐานข้อมูล SQLite จะเกิดหลักการใดของ CIA Triad?

ตอบ: C. Confidentiality, because credentials are exposed to anyone with database read access

คำอธิบาย: การเก็บรหัสผ่านโดยไม่เข้ารหัส (Plaintext) ทำให้ใครก็ตามที่มีสิทธิ์อ่านฐานข้อมูลสามารถเห็นข้อมูลรหัสผ่านได้ทันที ซึ่งเป็นการละเมิดหลักการรักษาความลับของข้อมูล (Confidentiality)

Q2: หากตาราง audit_log ถูกลบทิ้ง (dropped) จะกระทบต่อหลักการใดของ CIA Triad มากที่สุด?

ตอบ: C. Integrity

คำอธิบาย: ตารางบันทึกการตรวจสอบ (Audit log) มีไว้เพื่อบันทึกเหตุการณ์ต่างๆ อย่างถูกต้อง การที่ตารางนี้ถูกทำลายหรือลบทิ้งไป ส่งผลกระทบโดยตรงต่อความสมบูรณ์และถูกต้องของข้อมูล (Integrity) ทำให้ไม่สามารถตรวจสอบย้อนหลังได้ (สูญเสีย Accountability / Non-repudiation)

Q3: การฉวยพรหัสผ่านระดับ Admin 3 บัญชีที่ทีม IT ไม่เคยสร้างขึ้น บ่งบอกถึงภัยคุกคามประเภทใด?

ตอบ: B. Privilege escalation and persistence mechanism

คำอธิบาย: การพบรหัสผ่านระดับผู้ดูแลระบบ (Admin) ที่ไม่ได้รับอนุญาต มักเป็นผลมาจากการที่แฮกเกอร์สามารถยกระดับสิทธิ์ (Privilege escalation) ของตนเองได้ และสร้างบัญชีทิ้งไว้เพื่อใช้เป็นช่องทางในการกลับเข้ามาในระบบอีกในอนาคต (Persistence)

Q4: ข้อความ OR 1=1 ในแบบฟอร์มล็อกอินคือการโจมตีแบบใด และกระทบหลักการใดใน CIA Triad?

ตอบ: B. SQL Injection - Confidentiality

คำอธิบาย: ข้อความ ' OR 1=1 -- เป็นคำสั่งคลาสสิกที่ใช้ในการทำ SQL Injection เพื่อหลอกให้ฐานข้อมูลคืนค่าเป็นจริง (True) เสมอ ทำให้แฮกเกอร์สามารถข้ามผ่านหน้าล็อกอินเข้าไปเข้าถึงข้อมูลสำคัญได้ ซึ่งส่งผลกระทบต่อความลับของข้อมูล (Confidentiality)

Q5: หากการเชื่อมต่อฐานข้อมูล MySQL ไม่ได้ใช้ TLS encryption นักวิเคราะห์ควรทำสิ่งใดเป็นอันดับแรก?

ตอบ: B. Enable TLS/SSL on the MySQL connection to encrypt data in transit

คำอธิบาย: เมื่อระบบตรวจสอบพบว่าไม่มีการเข้ารหัสข้อมูลขณะส่งผ่านเครือข่าย วิธีแก้ปัญหาดังกล่าวโดยตรงคือการเปิดใช้งาน TLS/SSL เพื่อเข้ารหัสข้อมูลที่กำลังเคลื่อนที่ (Data in transit) ป้องกันการถูกดักจับข้อมูลระหว่างทาง

Q6: หากคอลัมน์ expires_at ในตารางเซสชันมีค่าเป็น NULL ทุกแถว จะเกิดความเสี่ยงใด?

ตอบ: A. Broken Authentication - stolen tokens remain valid indefinitely

คำอธิบาย: ค่า NULL ในช่องเวลาหมดอายุหมายความว่าเซสชันหรือ Token ของผู้ใช้นั้นจะไม่มีวันหมดอายุ หากมีผู้ไม่หวังดีขโมย Token นี้ไปได้ก็จะสามารถนำไปใช้งานสวมรอยได้ตลอดไป ซึ่งเป็นช่องโหว่ด้าน Broken Authentication

Q7: ระบบต้องการ Uptime 99.99% แต่ใช้ไฟล์ SQLite เก็บไว้บนเครื่อง PC ธรรมดาและไม่มีการแบคอัพ กระทบ CIA ข้อใดและควรแก้อย่างไร?

ตอบ: B. Availability - migrate to a clustered RDBMS with automated replication and failover

คำอธิบาย: การใช้เครื่อง PC เดียวๆ และไม่มีการสำรองข้อมูล (No replication or backup) ขัดแย้งกับความต้องการที่ระบบต้องพร้อมใช้งานสูง (Uptime 99.99%) ซึ่งมีความเสี่ยงสูงที่จะเกิดการล่ม (Availability) จึงควรเปลี่ยนไปใช้ระบบฐานข้อมูลแบบคลัสเตอร์ที่สามารถทำงานทดแทนกันได้อัตโนมัติ (Automated replication and failover)

Q8: การ Export ข้อมูลออกมาเป็นไฟล์ CSV เพื่อนำไปวิเคราะห์แบบออฟไลน์โดยนักวิเคราะห์ Forensics จัดอยู่ในขั้นตอนใดของ Incident Response (NIST SP 800-61)?

ตอบ: B. Detection and Analysis

คำอธิบาย: การดึงข้อมูลออกมาวิเคราะห์เพื่อตรวจสอบการโจมตี (Forensic analysis) เป็นกระบวนการทำความเข้าใจขอบเขตและลักษณะของภัยคุกคาม ซึ่งจัดอยู่ในช่วง Detection and Analysis (การตรวจจับและวิเคราะห์)

Q9: การเขียน Trigger ให้ระบบทำการบันทึก (Insert into audit_log) ทุกครั้งที่มีการล็อกอิน จัดเป็น Security Control ประเภทใด?

ตอบ: C. Detective Control

คำอธิบาย: การบันทึกเหตุการณ์ต่างๆ (Logging/Auditing) ไม่ได้ป้องกันไม่ให้เกิดเหตุการณ์เกิด แต่มีไว้เพื่อให้สามารถเข้ามาตรวจสอบย้อนหลังได้เมื่อมีสิ่งผิดปกติ จึงถือเป็นการควบคุมแบบตรวจจับ (Detective Control)

Q10: การเชื่อมต่อ MongoDB ได้โดยไม่ต้องใส่รหัสผ่าน และมีสิทธิ์อ่าน/เขียนเต็มรูปแบบ จัดเป็นช่องโหว่ประเภทใด และกระทบ CIA ส่วนใดบ้าง?

ตอบ: B. Misconfiguration / Missing Authentication - Confidentiality, Integrity, and Availability

คำอธิบาย: การเปิดให้เข้าถึงฐานข้อมูลได้โดยไม่ต้องยืนยันตัวตน (Missing Authentication) ทำให้ผู้โจมตีสามารถอ่านข้อมูล (กระทบ Confidentiality), แก้ไขข้อมูล (กระทบ Integrity), และสามารถลบทำลายข้อมูล (กระทบ Availability) ได้อย่างอิสระ